

Уязвимости, приводящие к DOS

Описание проблемы

DoS — атака на вычислительную систему с целью довести её до отказа, то есть создание таких условий, при которых добросовестные пользователи системы не смогут получить доступ к предоставляемым системным ресурсам (серверам), либо этот доступ будет затруднён. Отказ целевой системы может быть и шагом к овладению системой (если в нештатной ситуации ПО выдаёт какую-либо критическую информацию — например, версию, часть программного кода и т. д.). Но чаще это мера экономического давления: потеря простой службы, приносящей доход, счета от провайдера и меры по уходу от атаки ощутимо бьют по карману «цели».

DDoS - частный случай DOS-атаки, когда для ее реализации используется большое количество запросов. Варианты атак:

- Атаки, направленные на истощение ресурса хоста. Хакер отправляет на объект атаки специальные пакеты, на обработку которых сервер затрачивает все свои ресурсы. В результате происходит перерасход мощности процессора, памяти и других систем, и хост временно выходит из строя.
- Атаки, насыщающие полосу пропускания. Злоумышленник отправляет на атакуемый объект большое число пакетов и перенасыщает полосу пропускания сети. Это можно сделать двумя способами: используя подключение с большей полосой пропускания по сравнению с полосой хоста и заполняя его множественными пакетами, или наоборот, используя медленный канал связи (модемное соединение) и определенную технологию отправки пакетов со множества компьютеров сети.
- Атаки искаженными сетевыми пакетами. Такую атаку также можно выполнить двумя способами. Во-первых, отправляя на атакуемый сервер некорректные пакеты, которые нарушают работу операционной системы или сетевого ПО. Во-вторых, отправляя фальсифицированные пакеты, которые вынуждают хост изменить собственные настройки или конфигурацию системы. Эти атаки рассчитаны на уязвимость системы защиты или ошибки в коде ПО.

Примеры

1. На сайте есть форма добавления файла. Если разработчик не реализовал проверку размера файла, то пользователь может передать файл произвольного размера. Сервер при обработке этого файла может не справиться с такой объемной задачей. Как результат, либо пользователи не смогут воспользоваться данной функциональностью, либо сервис вообще станет недоступен.
2. Допустим у нас есть "тяжелый" метод, который съедает большое количество ресурсов. Если злоумышленник вызовет такой метод неограниченное количество раз, он может занять большую часть мощностей, из-за чего у системы могут возникнуть проблемы с доступностью.
3. Передача методу БЛ слишком маленькой/большой даты (01-01-1900/31-12-2100) в некоторых случаях заставит и без того «нелегкий» метод работать еще дольше.

XML-бомба

XML-бомба (Атака на миллиард смехов) это тип атаки типа "отказ в обслуживании" (DoS), которая нацелена на анализаторы XML, перегружая их огромным количеством вложенных объектов и повторяющихся данных. Атака предназначена для использования способа расширения объектов анализаторами XML, что может привести к использованию анализатором чрезмерного объема памяти и ресурсов процессора, что в конечном итоге приведет к отказу в обслуживании целевой системы. Часть атаки "Миллиард смехов" относится к повторному использованию небольшого набора символов для создания большого количества вложенных объектов, что приводит к экспоненциально растущему объему данных. Такой подход можно использовать и с другими технологиями: PNG, ZIP, XLS и т.д.

Последствия эксплуатации

Успешная реализация DOS-атаки приведет к остановке бизнес процессов у клиентов, а при худшем сценарии с недоступности всей системы. К примеру, остановка работы сервера онлайн-аукциона eBay всего на полчаса в 2000 году нанесла ущерб компании в несколько сот тысяч долларов.

Как исправить?

1. Установить [защиту от частых вызовов](#) для "тяжелых" методов.
2. Проводить нагрузочное тестирование для определения стойкости функционала к высокой нагрузке.
3. Валидировать входные данные - размер и тип передаваемого файла, диапазон дат и т.д.